

Patch Management Policy

Created for: Shameless Ltd.

Created by: Gill Ltd.

Version 1.3

Date: 05/08/2024

Template provided by SANS Institute

(<https://www.sans.org/information-security-policy/?page=2>)

Confidential

OVERVIEW

Unsecured and vulnerable servers continue to be a major entry point for malicious threat actors. Known vulnerabilities allow for known exploitations to be performed on potentially sensitive Shameless systems. Timely and effective patch management is essential for mitigating these risks and maintaining the security posture of Shameless. This policy outlines the responsibilities for identifying, prioritizing, and applying software patches and updates across the organization's information systems.

PURPOSE

The purpose of the Patch Management policy is to establish standards for the base updating measures of internal server equipment that is owned and/or operated by Shameless. Employees will be able to understand the importance of ensuring systems are up-to-date and the impact not doing so can have on Shameless. Effective implementation of this policy will minimize unauthorized access to Shameless proprietary information and technology. Data losses will be mitigated, along with the assurance that business operations won't suffer from out of date technology and systems.

SCOPE

All employees, contractors, consultants, temporary and other workers at Shameless and its subsidiaries must adhere to this policy. This policy applies to server equipment and systems that are owned, operated, or leased by Shameless or registered under a Shameless-owned internal network domain.

POLICY

1. All internal servers and systems deployed at Shameless must be owned by an operational group that is responsible for system administration. Approved server/system updating guides must be established and maintained by each operational group, based on business needs, and approved by the information security team. Operational groups should monitor configuration compliance and implement an exception policy tailored to their environment. Each operational group must establish a process for changing the configuration guides, which includes review and approval by the information security team.
2. Servers and systems must be registered within the corporate enterprise management system. At a minimum, the following information is required to positively identify the point of contact:
 - a. Server contacts and location, along with backup contacts

- b. Hardware and Operating System information, including type, version, update date, etc.
 - c. Main functions and applications of the server/system
- 3. Information provided to the enterprise management system must be kept up-to-date and organized for easy accessibility by authorized users.
- 4. Shameless will utilize automated vulnerability scanning tools to identify missing patches and security vulnerabilities across its information systems.
 - a. The Help Desk will be responsible for monitoring these systems, along with aid of the Head of IT when applicable.
 - b. Vulnerabilities will be prioritized based on severity ratings, exploitability, and potential impact on business operations. (refer to risk register to understand severity calculations)
- 5. Prior to deployment, patches will undergo testing in a controlled environment to assess compatibility and verify that they do not introduce new issues or conflicts.
 - a. Patch deployment schedules will be established based on the criticality of the vulnerability, with priority given to critical and high-risk patches.
- 6. System administrators will be tasked with applying patches to their respective systems and documenting patching activities.
 - a. Comprehensive documentation of patch management activities, including patch identification, testing results, deployment schedules, and verification records, will be maintained.
- 7. Services and applications that will not be used must be disabled where practical.
- 8. Servers and systems should be physically located in an access-controlled, secured environment.

POLICY COMPLIANCE

Compliance with the Patch Management Policy will be monitored by the information security team through periodic vulnerability assessments, patch deployment reports, and internal audits. To assess employee awareness and adherence to the policy, simulated patching exercises may be conducted periodically to gauge response and compliance. Non-compliance with the Patch Management Policy may result in disciplinary action, including warnings, training requirements, or termination of employment, depending on the severity and frequency of violations.

VERSION HISTORY

Date	Author	Version	Description
05/05/2024	Sampy Gill	1.0	Created title page and outline of subsection

05/05/2024	Sampy Gill	1.1	Completed Overview, Purpose, and Scope subsections
05/06/2024	Sampy Gill	1.2	Worked on Policy subsection
05/08/2024	Sampy Gill	1.3	Completed Policy and Policy Compliance subsections